

Committee on National Security Systems



CNSSD 506
January 2019

NATIONAL DIRECTIVE TO IMPLEMENT PUBLIC KEY INFRASTRUCTURE ON SECRET NETWORKS

THIS DOCUMENT PRESCRIBES MINIMUM
STANDARDS. YOUR DEPARTMENT OR AGENCY
MAY REQUIRE FURTHER IMPLEMENTATION.



CHAIR

FOREWORD

1. The Committee on National Security Systems Directive (CNSSD) 506, *National Directive to Implement Public Key Infrastructure on Secret Networks*, outlines the requirements for integrating the use of certificates issued by the National Security Systems (NSS) Public Key Infrastructure (PKI) into systems operating on Secret networks to protect resources while achieving interoperability and controlled information sharing.
2. The Committee on National Security Systems Policy (CNSSP) 25, *National Policy for Public Key Infrastructure in National Security Systems* (Reference a), establishes the NSS PKI, outlines the measures for using the NSS PKI to protect information on national security systems on Secret networks, requires CNSS departments and agencies to obtain PKI support from the NSS PKI, and establishes the NSS PKI Member Governing Body (MGB) to oversee and provide additional guidance for the NSS PKI.
3. The Committee on National Security Systems Instruction (CNSSI) 1300, *Instruction for National Security Systems Public Key Infrastructure X.509 Certificate Policy* (Reference b), identifies the requirements for the operation of the NSS PKI.
4. This Directive supersedes CNSSD 506, *National Directive to Implement Public Key Infrastructure for the Protection of Systems Operating on Secret Level Networks*, October 2012.
5. This Directive is available from the CNSS Secretariat, as noted below, or the CNSS website: www.cnss.gov.

DONALD R. HECKMAN

CNSS CHAIR

**NATIONAL DIRECTIVE
TO IMPLEMENT PUBLIC KEY INFRASTRUCTURE
ON SECRET NETWORKS**

SECTION I – PURPOSE

1. This Directive establishes the requirement for all United States Government (USG) Departments and Agencies (D/A) to implement the National Security Systems (NSS) Public Key Infrastructure (PKI) to promote interoperability and secure information sharing between USG D/As, and to use PKI to provide strong authentication to systems operating on Secret networks.

2. For purposes of this Directive, PKI refers to products and services that provide and manage X.509 certificates for public key cryptography.

SECTION II – AUTHORITY

3. The authority to issue this Directive derives from National Security Directive (NSD) 42, *National Policy for the Security of National Security Telecommunications and Information Systems* (Reference c), which outlines the roles and responsibilities for securing national security systems consistent with applicable law, Executive Order (E.O.) 12333, *United States Intelligence Activities* (Reference d), and other Presidential directives.

4. Nothing in this Directive alters or supersedes the authorities of the Director of National Intelligence.

SECTION III – SCOPE

5. This Directive applies to all USG D/As and their supporting contractors and non-federal affiliates (state, local, tribal, and territorial) who own, operate, or maintain NSS operating at the Secret level.

6. The scope of this Directive is also defined in accordance with E.O. 13587, *Structural Reforms to Improve the Security of Classified Networks and the Responsible Sharing and Safeguarding of Classified Information* (Reference e), to include any classified system operated by, on behalf of, or in support of any USG D/A.

SECTION IV – POLICY

7. This Directive mandates the development and implementation of a comprehensive approach to the use of PKI to protect USG NSS. All USG D/As and their supporting contractors who own, operate, or maintain NSS operating at the Secret level must follow this Directive in the implementation and use of NSS PKI for all systems residing on Secret networks, including systems that reside on closed operational networks.

8. D/As must establish and implement plans and policies for the issuance, and integration of the use of certificates issued by the NSS PKI to authenticate users and strengthen access control decisions to D/A NSS. In addition, all USG D/As must include provisions in their D/A plans and policies covering the operation and use of NSS PKI by the supporting contractors for whom they sponsor access to classified information.

9. D/As must designate and maintain an agency lead official for ensuring the execution of the D/A NSS PKI implementation plan. D/As must provide contact information to the NSS PKI Policy Management Authority (PMA) as defined in CNSSI 1300 (Reference b).

10. D/As must issue certificates from the NSS PKI as follows:

- a. Department of Defense (DoD), Department of State (DOS), and Federal Bureau of Investigation (FBI) must either operate Certification Authorities (CA) under the NSS PKI Root CA or must obtain certificate services from the DoD operated Common Service Provider (CSP). All other D/As must obtain certificate services from the CSP.
- b. D/As must issue NSS PKI certificates housed on National Security Agency (NSA) approved hardware tokens to individuals who require access to applications that require NSS PKI for authentication.
- c. D/As must issue certificates to systems and devices to support device authentication to other devices and to applications that require NSS PKI.

11. D/As must use the NSS PKI for the following capabilities:

- a. As the means of authentication to support cryptographic network logon to D/A Secret networks that interconnect with other D/A Secret networks.
- b. As the means of authentication for access to information resources as determined by the D/A. See paragraph 12 for additional guidance on using the NSS PKI to support interoperability and information sharing.
- c. As the preferred means of authentication for access to closed operational networks. See paragraphs 13 and 14 for additional guidance on authentication for closed operational networks.
- d. As the preferred means for digitally signing code, documents, or emails; and the preferred means for encrypting emails.

12. D/As must do the following to enable information systems, which reside on D/A Secret networks that interconnect with other D/A Secret networks, to leverage the NSS PKI to support interoperability and information sharing.

- a. Accept the identity asserted in valid NSS PKI certificates based on NSS PKI-wide adherence to the identity vetting and validation requirements defined in CNSSI 1300 (Reference b).
- b. Ensure that D/A email systems can accept digitally signed emails.

- c. Ensure that web servers and other information systems are configured to be able to validate certificates issued by any NSS PKI CA.
- d. Ensure that guards and other mechanisms established to interconnect D/A networks can support NSS PKI certificate services, including digital signatures, encryption, and access to CA certificates and Certificate Revocation Lists (CRL).

13. D/As may deploy Non-Person Entity (NPE) Only Locally Trusted (OLT) CAs to support the need to issue certificates to NPEs that will only be trusted within the D/A network. NPE OLT CAs may be operated as standalone systems or may be part of a D/A NPE OLT PKI. All CAs within an NPE OLT PKI must meet the following guidelines:

- a. NPE OLT CAs must only be used for certificates issued to system or device subscribers as defined in CNSSI 1300 (Reference b). Certificates intended for name or role subscribers must be issued by the NSS PKI using NSS PKI policy Object Identifiers (OID) as defined in CNSSI 1300 (Reference b).
- b. NPE OLT CAs must only be used when the use of the certificate issued to the NPE is inherently bound to the network where both the NPE OLT CA and the NPE are located. Certificates used to interact with relying parties outside of the network, or that may at any time support relying parties outside of the network, must be issued by the NSS PKI using NSS PKI system or device policy OIDs as defined in CNSSI 1300 (Reference b).
- c. NPE OLT CAs must not assert NSS PKI policy OIDs identified in Section 1.2 of CNSSI 1300 (Reference b).
- d. D/As must provide a briefing to the NSS PKI Member Governing Body (MGB) that includes the following:
 - (1) Description of the planned high-level conceptual architecture for NPE OLT CAs.
 - (2) Description of the intended scope for certificate issuance by the D/A NPE OLT CAs.
 - (3) Agreement that the D/A will develop one or more Certification Practice Statements (CPS) for their NPE OLT CAs and operate those CAs in compliance with the D/A specific CPSs.
 - (4) Agreement that the D/A will provide a statement after one year of operation, and updated every three years thereafter, attesting compliance with the D/A's NPE OLT CA CPS(s).
 - (5) Agreement that the D/A will provide an updated briefing to the NSS PKI MGB in the event of a change to the architecture or intended scope.

The NSS PKI MGB will review the architecture and planned scope to ensure that they fall within scope and vote to accept the NPE OLT CAs.

- e. D/As must perform the following on-going activities when operating NPE OLT CAs:

- (1) Develop and maintain the NPE OLT CA CPS(s).
- (2) Provide a statement to the NSS PKI MGB after one year of operation, and updated every three years thereafter, attesting compliance with the D/A's NPE OLT CA CPS(s).
- (3) Provide an updated briefing to the NSS PKI MGB if there are changes to the architecture or scope for the D/A NPE OLT CA usage.

14. Operation of a D/A internal PKI for a closed operational network that is not part of the NSS PKI, defined in paragraph 11, and does not meet the guidelines for an NPE OLT PKI, defined in paragraph 13, is discouraged. D/A internal PKIs must have a compelling operational justification and must not adversely affect the potential capability for interoperability between D/A networks. Authorization to operate a D/A internal PKI must be requested from the NSS PKI PMA. If authorization is not approved, the D/A must develop and implement a plan to migrate from the D/A internal PKI to the NSS PKI. The migration plan may include the issuance of a cross-certificate from the NSS PKI Root CA to support short-term interoperability.

SECTION V – RESPONSIBILITIES

15. Each D/A must:

- a. Adhere to the NSS PKI standards specified in CNSSP 25 (Reference a) to protect NSS and National Security Information (NSI) on Secret networks.
- b. Designate an agency lead official for ensuring the issuance of the D/A's implementation plans and policies.
- c. Identify funding to implement and sustain the D/A's NSS PKI capability.
- d. Implement D/A policy specifying the use of NSS PKI as the means of authentication.
- e. Issue certificates to employees and supporting contractors and non-federal affiliates with accounts on the D/A's Secret networks.
- f. Use NSS PKI for authentication, digital signature, and encryption.
- g. Use NSS PKI for authentication to D/A applications and websites.
- h. For D/As using the CSP, execute the appropriate Memorandum of Agreement with the CSP detailing roles and responsibilities.
- i. Submit NPE OLT PKI or CA information to the NSS PKI MGB.

16. The NSS PKI PMA must:

- a. Coordinate with agency lead officials for the implementation of this Directive.
- b. Operate and maintain the NSS PKI Root CA and maintain the NSS PKI Root CA CPS in accordance with CNSSI 1300 (Reference b).
- c. Approve D/A and CSP CPSs, as recommended by the NSS PKI MGB.

- d. Review D/A requests to operate a D/A internal PKI that is not part of the NSS PKI and does not meet the guidelines for an NPE OLT PKI and make an authorization decision.
17. The NSS PKI MGB must:
- a. Coordinate with agency lead officials to support interoperability of NSS PKI solutions across Secret networks.
 - b. Review and make a recommendation to the NSS PKI PMA for D/A and CSP CPSs to ensure the availability of certificates to support the use of NSS PKI.
 - c. Review D/A requests and operational updates for a D/A NPE OLT PKI or CA.
18. The NSS PKI CSP, as operated by the DoD, must:
- a. Provide a mechanism for issuing certificates on a fee-for-service basis for D/As that do not operate their own CAs under the NSS PKI Root CA.
 - b. Publish CRLs, as required by CNSSI 1300 (Reference b).

SECTION VI – DEFINITIONS

19. Terms used in this Directive are defined in CNSSP 25 (Reference a) and CNSSI 4009, *Committee on National Security Systems (CNSS) Glossary* (Reference f).

SECTION VII – REFERENCES

20. References used in this Directive are listed below. Future updates to referenced documents must be considered applicable to this Directive.
- a. Committee on National Security Systems Policy 25, *National Policy for Public Key Infrastructure in National Security Systems*, December 2017.
 - b. Committee on National Security Systems Instruction 1300, *Instruction for National Security Systems Public Key Infrastructure X.509 Certificate Policy*, December 2014.
 - c. National Security Directive 42, *National Policy for the Security of National Security Telecommunications and Information Systems*, July 5, 1990.
 - d. Executive Order 12333, *United States Intelligence Activities*, December 4, 1981, as amended.
 - e. Executive Order 13587, *Structural Reforms to Improve the Security of Classified Networks and the Responsible Sharing and Safeguarding of Classified Information*, October 7, 2011.
 - f. Committee on National Security Systems Instruction 4009, *Committee on National Security Systems (CNSS) Glossary*, April 6, 2015.